BİLGİ SİSTEMLERİ GÜVENLİK VE DENETİM RAPORU: VolkanBank

Yönetim Özeti

VolkanBank altyapısında gerçekleştirilen güvenlik denetimi sonucunda, kurumun erişim yönetimi ve parola politikalarında acil müdahale gerektiren kritik zafiyetler tespit edilmiştir. İşten aylar önce ayrılmış bir personelin sistemde en yüksek yetkilerle aktif kalmaya devam etmesi, iç ağa dışarıdan yetkisiz erişim riskini en üst seviyeye çıkarmıştır. Sistemde ortak hesap kullanımına izin verilmesi işlemlerdeki sorumluluk tespitini imkansız kılarken, Çok Faktörlü Kimlik Doğrulama ve parola güvenliği önlemlerinin eksikliği siber saldırılara karşı büyük zayıflık içermektedir.Bankanın itibarını ve müşteri verilerini korumak ve olası ağır yasal/finansal yaptırımları önlemek için erişim ve denetim prosedürlerinin acilen yasal mevzuat ve standartlara uygun hale getirilmesi gerekmektedir.

1. Tespit Edilen Denetim Bulguları

Bulgu 1: Zombi Hesap ve İşten Ayrılış Sürecinin Doğru İşlememesi

- **Risk:** Dokümanlarda Burak Çetin isimli personelin 14 ay önce işten ayrıldığı belirtilmesine rağmen hesabının (burak.cetin) hala aktif olduğu tespit edilmiştir. Bu hesap son olarak 412 gün önce giriş yapmış olup, parolasının süresiz (Password Never Expires) olarak ayarlandığı görülmektedir. Daha da kritik olarak bu hesap "Domain Admins", "VPN Users" ve "Internet Banking Admins" gibi en ayrıcalıklı grupların üyesidir.Çok zayıf parolaya ve geniş yetkilere sahip bu hesap kritik riskli ve çok ağır sonuçlara sebep verebilecek siber saldırılara karşı savunmasızdır.

- **Etki:** İşten ayrılmış bir personelin en yüksek yetkilere sahip hesabının aktif kalması, sistemin tamamen ele geçirilmesine, müşteri verilerinin sızdırılmasına ve içeriden/dışarıdan gelebilecek kritik güvenlik ihlallerine yol açar.

- **Öneri:** İnsan Kaynakları ile Bilgi Teknolojileri birimleri arasındaki kimlik ve erişim yönetimi (IAM) entegrasyonu acilen sağlanmalı, işten ayrılan personellerin tüm sistem erişimleri anında devre dışı bırakılmalıdır ve personelin bu konuda çok daha dikkatli olması sağlanmalıdır.

Bulgu 2: Zayıf Parola Politikası (Password Policy) Zafiyetleri

- **Risk:** CIO'nun şifre kontrollerinin güçlü olduğu yönündeki beyanının aksine; mevcut parola politikasında Karmaşıklık (Complexity) ve MFA gereksinimleri sadece "Opsiyonel" (İsteğe Bağlı) bırakılmıştır. Ayrıca Parola Süre Sonu (Expiry) ve Hesap Kilitleme (Account Lockout) tamamen devre dışı (Disabled) durumdadır.

- **Etki:** Bu eksiklikler, sistemi ve müşteri verilerini Kaba Kuvvet (Brute-Force) siber saldırılarına karşı tamamen savunmasız bırakmakta ve yetkisiz erişim riskini en üst düzeye çıkarmaktadır.

- **Öneri:** Sektör standartlarına (örneğin ISO 27001 veya PCI-DSS) uygun olarak parola karmaşıklığı zorunlu hale getirilmeli, hesap kilitleme mekanizması (örneğin 5

hatalı denemede) derhal aktif edilmelidir.Ayrıca belirli periyotlarda şifre değişiklikleri zorunlu hale getirilmelidir.

Bulgu 3: Zayıf Hash Algoritması Kullanımı ve Parola İfşası

- **Risk:** Veritabanından çekilen parolaların artık güvensiz ve miladı dolmuş olan MD5 algoritması ile şifrelendiği görülmüştür. Kullanıcıların parolaları (ahmet.yilmaz: password, selin.kaya: 12345678, burak.cetin: 1234, emre.ozkan: admin, ayse.turan: test) saniyeler içinde düz metin olarak açığa çıkarılmıştır.

- **Etki:** Kırılan hash değerleri organizasyondaki zayıf parola gerçeğini kanıtlamaktadır. MD5 kullanımı, veri tabanı sızıntılarında tüm personelin parolalarının anında ele geçirilmesiyle sonuçlanır.

- **Öneri:** Parola saklama mekanizmalarında MD5 kullanımı derhal terk edilmeli, şifreler Argon2, Bcrypt veya PBKDF2 gibi güvenli ve modern algoritmalarla saklanmalıdır.

Bulgu 4: Ortak (Shared) Hesap Kullanımı ve Hesap Verilebilirlik (Accountability) İhlali

- **Risk:** Yönetim, operasyonel kolaylık amacıyla "admin" ve "support" adlı ortak hesapların birden fazla kişi tarafından kullanılmasına izin vermiştir.

- **Etki:** Bu durum, sistem üzerinde gerçekleştirilen kritik bir işlemin, yapılandırma değişikliğinin veya siber güvenlik ihlalinin gerçekte hangi fiziksel kişi tarafından yapıldığının tespit edilmesini imkansız hale getirir. Hesap verilebilirlik ilkesi tamamen yok edilmiştir.

- **Öneri:** Tüm ortak hesaplar derhal kapatılmalıdır. Operasyonel destek amacıyla ortak hesap kullanımı kesinlikle zorunluysa, bu hesaplar Privileged Access Management çözümleri üzerinden uçtan uca çok sıkı loglanarak yönetilmelidir.

Bulgu 5: Kritik Sistemlerde MFA (Çok Faktörlü Kimlik Doğrulama) Eksikliği

- **Risk:** Müşteri verilerini barındıran hassas sistemlere erişimde ve VPN Portalında MFA devre dışı (Disabled) durumdadır.

- **Etki:** Yalnızca ele geçirilmiş bir kullanıcı adı ve zayıf bir parola ile (örneğin burak.cetin: 1234) dış ağdan kurumun iç ağına yetkisiz ve engelsiz erişim sağlanabilmektedir.

- **Öneri:** Yalnızca mobil uygulamalar için değil; VPN, sunucu erişimleri ve müşteri veri tabanlarına bağlanan tüm hesaplar (özellikle ayrıcalıklı kullanıcılar) için MFA zorunlu tutulmalıdır.

Bulgu 6: Ertelenen Erişim Gözden Geçirme (Access Review) Süreçleri

- **Risk:** Prosedürlerde ayrıcalıklı hesapların yılda bir gözden geçirileceği taahhüt edilmesine karşın, son inceleme 18 ay önce yapılmış ve güncel çalışma IT Güvenlik ekibi tarafından kaynak yetersizliği gerekçesiyle ertelenmiştir.

- **Etki:** Kontrol mekanizmasının çalışmaması sebebiyle, gereksiz yetkiye sahip olan kullanıcılar veya işten ayrılan personeller (Bulgu 1'de olduğu gibi) sistemde tam yetkiyle kalmaya devam etmektedir.

- **Öneri:** Erişim gözden geçirme çalışmaları kaynak kısıtlamalarına tabi tutulmamalı, düzenli ve zamanında yapılması yönetimin sorumluluğunda garanti altına alınmalıdır.

2. Yönetimin "Parolalarımız güçlüdür" İddiası Değerlendirmesi

Yönetimin (CIO) "Yetkisiz erişime karşı parola kontrollerimiz güçlü ve yeterlidir" şeklindeki beyanına **kesinlikle katılmıyorum**.

- **Neden:** Sistemdeki parola politikasında karmaşıklık (complexity) zorunlu tutulmamaktadır ve hesap kilitleme (lockout) devre dışıdır. Bu durum kaba kuvvet (Brute-Force) saldırılarına kapı aralamaktadır. Yapılan analizlerde, en yüksek yetkilere sahip yöneticilerin dahi *"1234"*, *"password"*, *"admin"* gibi son derece zayıf parolalar kullandığı, mevcut hash dosyasından net bir şekilde ispatlanmıştır. Parolalar sadece yetersiz değil, aynı zamanda siber saldırılara karşı tamamen korumasızdır.

3. Hash Değerleri İncelemesi

- **Kullanılan Algoritma:** Hash değerlerinin yapısı (32 karakter, onaltılık sistem) incelendiğinde **MD5**algoritmasının kullanıldığı tespit edilmiştir.

- **Güvenli Mi?:** Hayır. MD5 günümüzde siber güvenlik otoriteleri tarafından tamamen "kırık (broken)" ve güvensiz kabul edilmektedir.

- **Saldırı Riski:** Çarpışma (Collision) ve Gökkuşağı Tablosu (Rainbow Table) saldırılarına karşı savunmasızdır. Sıradan bilgisayarlar bile MD5 hashlerini saniyede milyarlarca kez hesaplayarak parolaları kolayca açığa çıkarabilir.(Bu şifreleri bulmam 10 saniyemi aldı)

- **Parolalar Hakkında Fikir:** Hashcat/John the Ripper gibi araçlarla anında çözülebilmeleri, personelin kullandığı şifrelerin (12345678, test vb.) sözlük (wordlist) saldırılarına karşı hiçbir direnci olmadığını göstermektedir.

4. En Kritik Bulgu Analizi

🚨 **En Kritik Bulgu:** İşten Ayrılan Personelin (Burak Çetin) Ayrıcalıklı Hesabının Aktif Kalması.

- **Risk:** 14 aydır kurumda çalışmayan bir kişinin hesabı "Domain Admins" ve "VPN Users" gruplarına üyedir ve parolası "1234"tür. Ayrıca şifre süresi dolmamaktadır (Never Expires).

- **İş Etkisi:** Kurumun iç ağına ve internet bankacılığı altyapısındaki tüm müşteri veritabanlarına tam yetkili, denetimsiz arka kapı (backdoor) erişimi oluşmuştur.

- **Olası Senaryo:** Kötü niyetli bir saldırgan, MFA koruması olmayan VPN portalı üzerinden, "burak.cetin" kullanıcı adı ve "1234" şifresi ile sisteme giriş yapar. Domain Admin yetkisiyle tüm güvenlik loglarını silebilir ve ağ içerisinde yanal hareket (Lateral movement) gerçekleştirerek bankacılık altyapısını ele geçirebilir.

- **Kuruma Potansiyel Zarar:** Müşteri verilerinin çalınması sonucu ağır yasal yaptırımlar (KVKK, BDDK cezaları vb.), finansal dolandırıcılık, sistemlerin fidye yazılımları ile kilitlenmesi ve bankanın pazar itibarının tamamen çökmesi.